

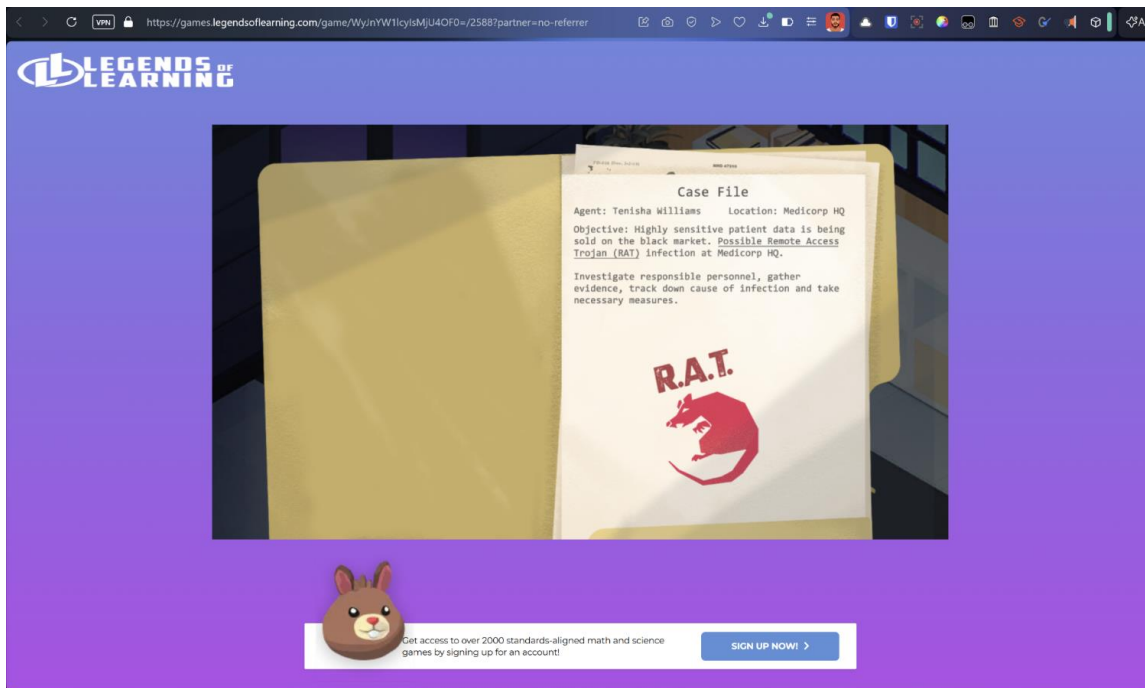
WS3.6 – Opdracht 2 - Basic Forensics



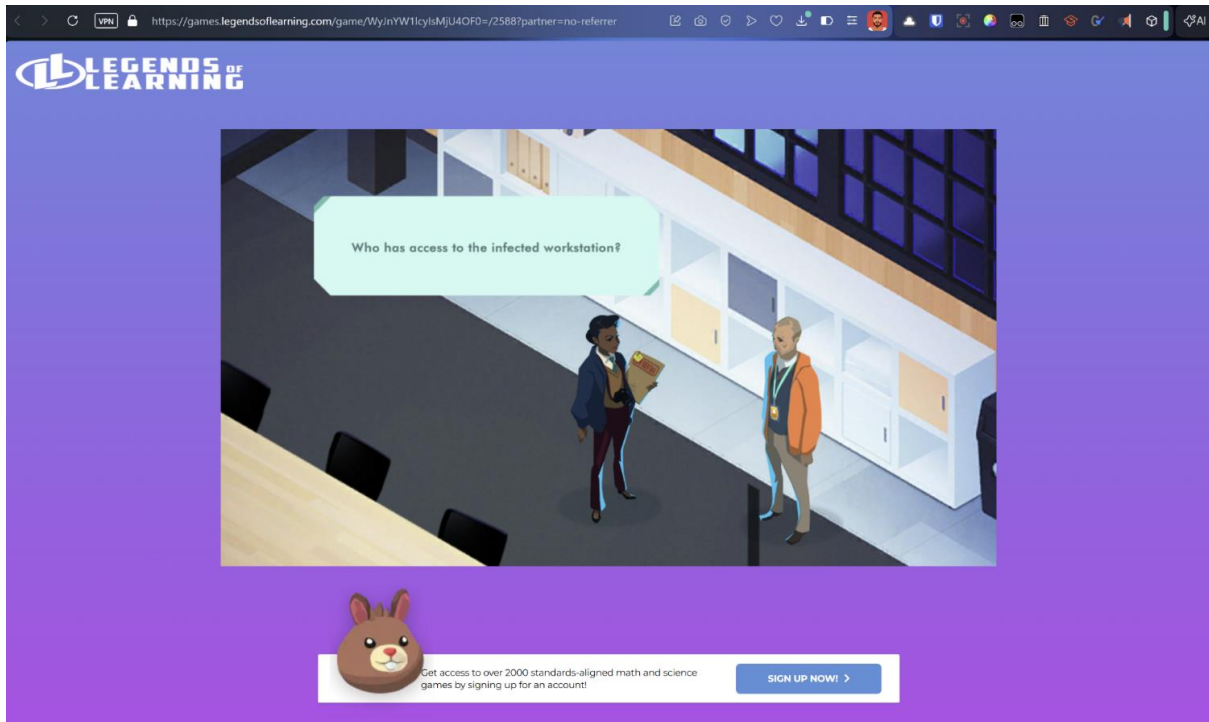
Groep: 10 – Firewall Force

Groepsleden: Bavli, Jonas, Lucas, Vo

Bij deze opdracht heb ik via een interactieve forensics-game onderzoek gedaan naar een vermoedelijke RAT-infectie binnen een zorgorganisatie, namelijk Medicorp HQ. In de briefing werd uitgelegd dat zeer gevoelige patiëntgegevens op de zwarte markt werden verkocht en dat er vermoedelijk sprake was van een Remote Access Trojan (RAT) op een werkstation binnen de organisatie. Mijn taak was om de situatie te onderzoeken, betrokken medewerkers te bevragen, digitaal bewijs veilig te stellen en vast te stellen hoe de besmetting was ontstaan en hoe deze kon worden gestopt.



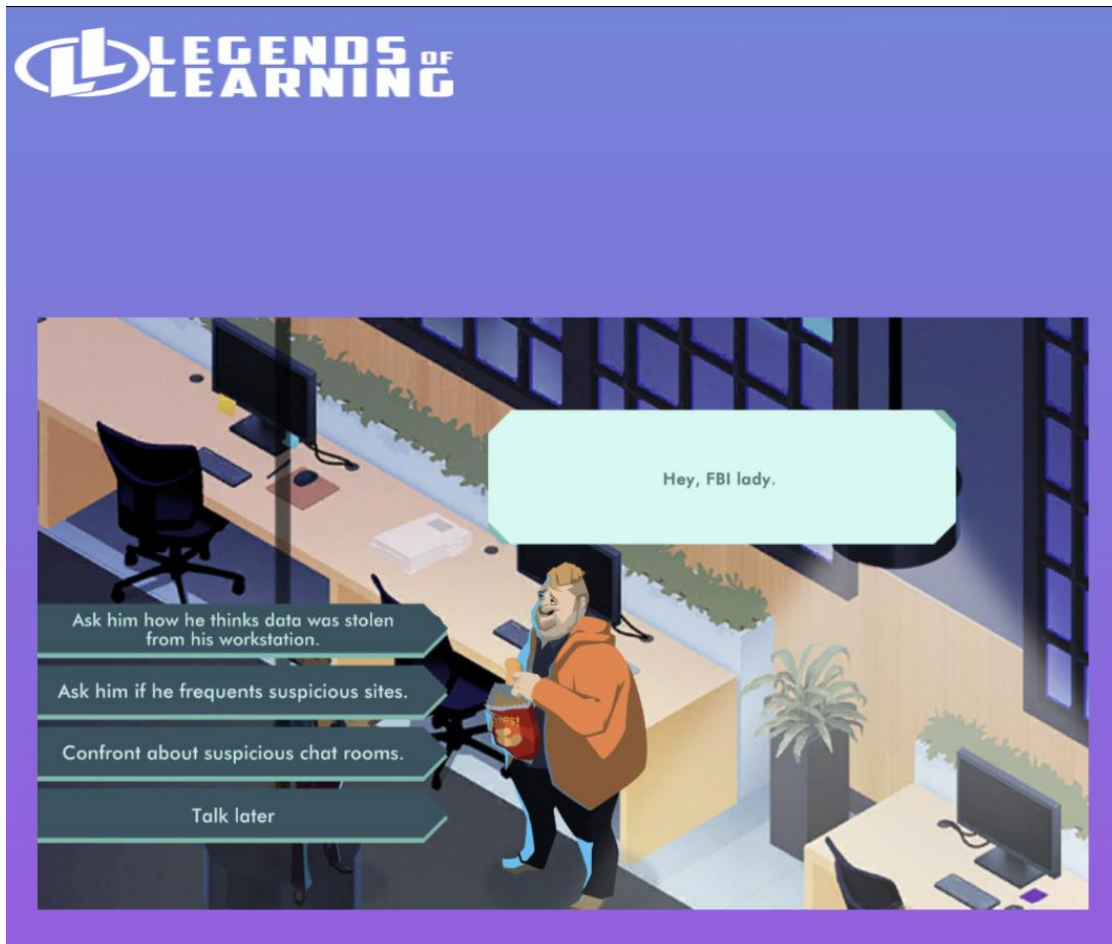
Ik begon het onderzoek door eerst informatie te verzamelen bij verschillende medewerkers op kantoor. De supervisor gaf aan dat alleen hijzelf en de werknemer die aan de computer was gekoppeld toegang hadden tot het geïnfecteerde werkstation. Ook vertelde hij dat de machine draaide op Windows 10 Professional en ongeveer een maand eerder opnieuw een image van was gemaakt. Een collega gaf vervolgens aanvullende context: gewone risicowebsites zoals social media, games en ongepaste websites zouden normaal gesproken geblokkeerd zijn, maar sommige medewerkers vonden daar soms manieren omheen. Diezelfde collega vermoedde ook dat de betrokken werknemer zich op ongepaste chatrooms begaf en mogelijk “catfished” was.







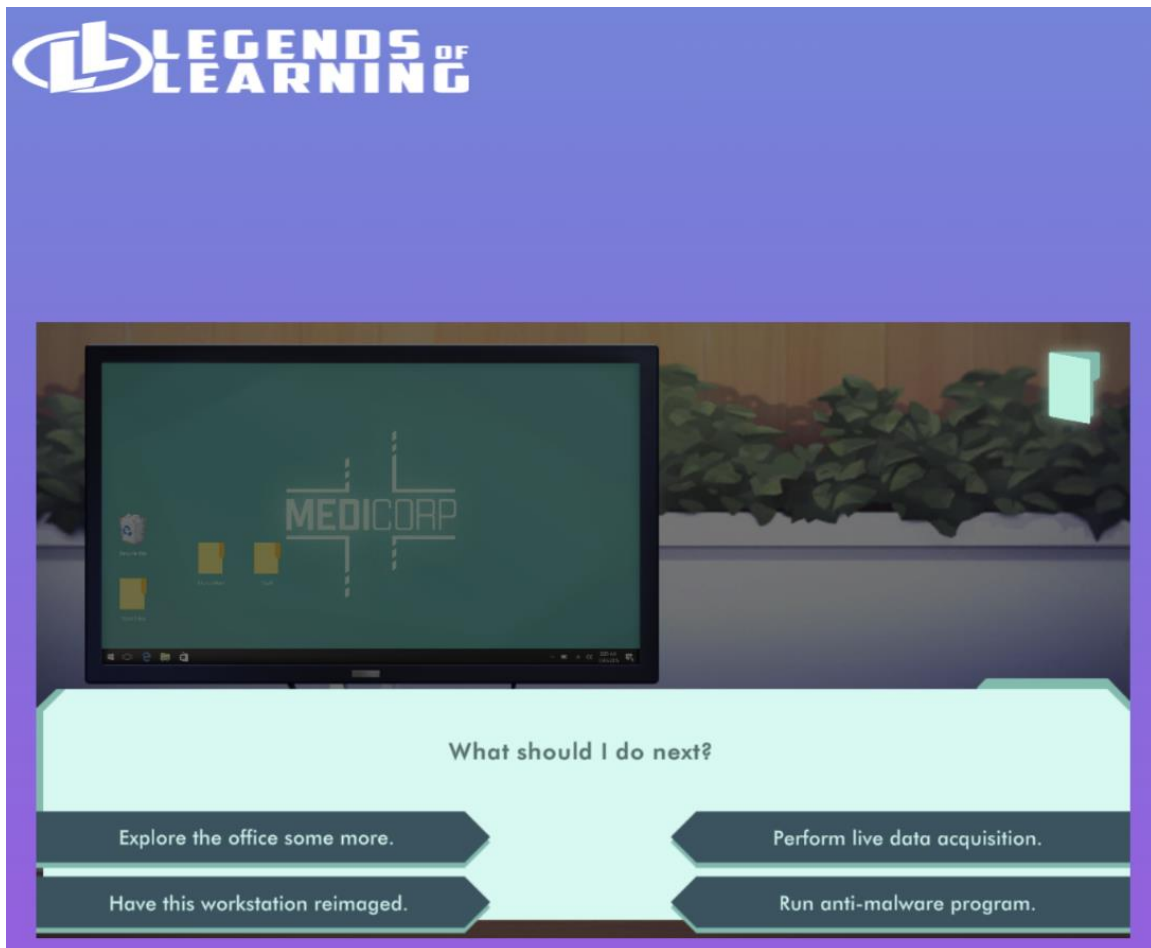
Daarna sprak ik de medewerker die verantwoordelijk was voor het gecompromitteerde workstation. In eerste instantie ontkende hij iets te weten, maar na confrontatie gaf hij toe dat hij een zip-bestand had ontvangen van een zogenaamde online “vriendin”. Hij zei dat dit bestand nog steeds op zijn computer stond en dat het vermoedelijk “rare dingen” met zijn systeem had gedaan. Daarmee werd al snel duidelijk dat de oorzaak waarschijnlijk niet alleen technisch was, maar ook sterk samenhang met menselijk gedrag, social engineering en het negeren van veilig internetgebruik op de werkvloer.



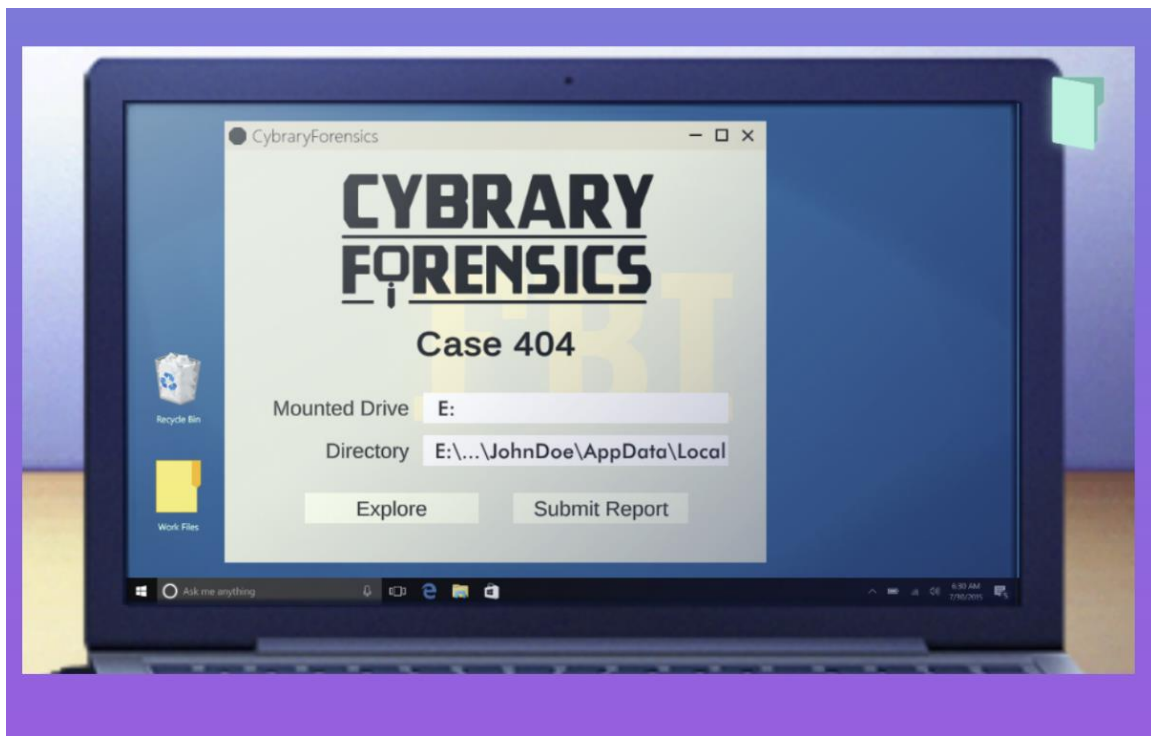


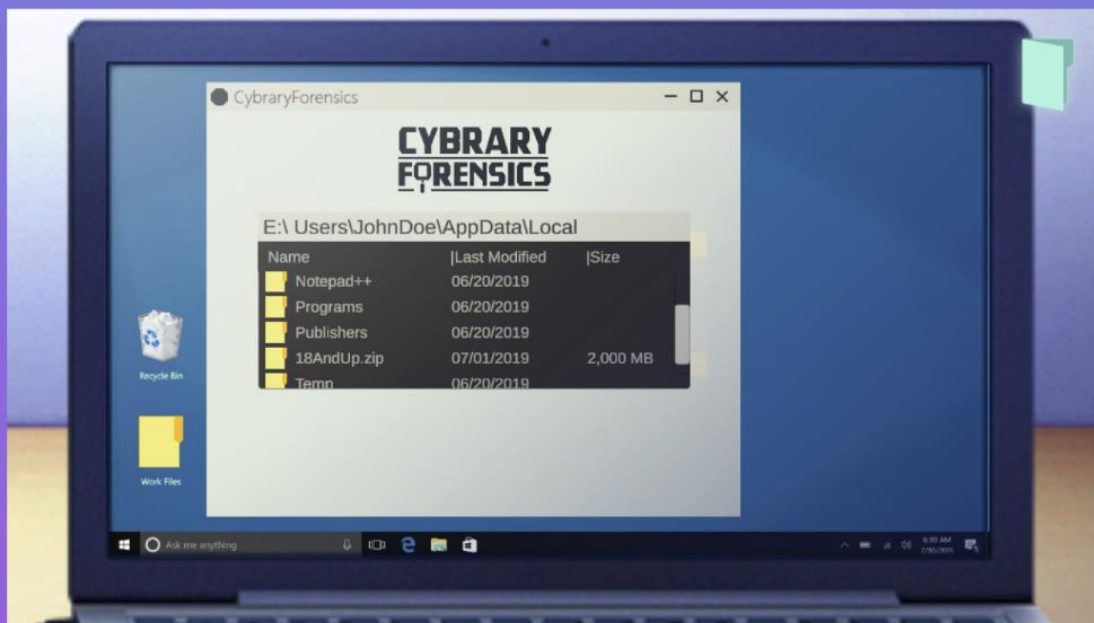


Vervolgens onderzocht ik het workstation zelf. Ik maakte eerst een kopie van de gecompromitteerde data als bewijsmateriaal en gebruikte daarna de forensische omgeving om de verkregen data te analyseren. In de map AppData\Local trof ik een verdacht bestand aan, namelijk 18AndUp.zip. Uit de analyse bleek dat hierin meerdere verdachte bestanden zaten, waaronder Important.exe en Java.exe. De forensische tool liet zien dat via deze bestanden gigabytes aan data waren weggesluisd naar het IP-adres 192.168.0.2. Ook bleek dat er registry keys waren aangemaakt, zodat de malware zichzelf automatisch opnieuw kon activeren. Dit wees duidelijk op persistence.

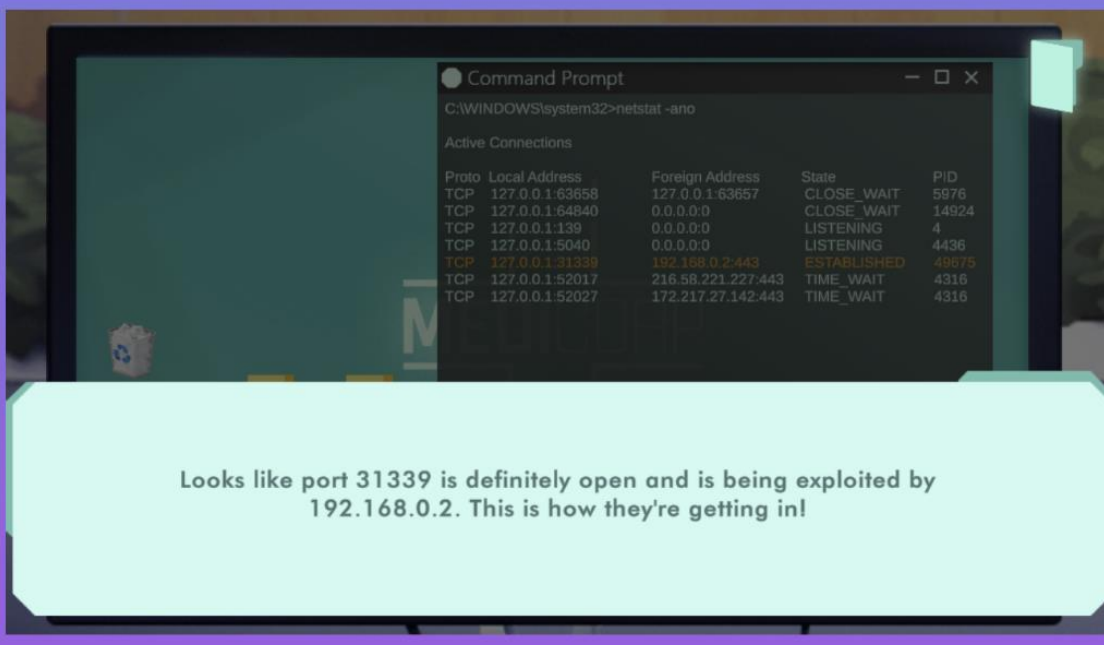








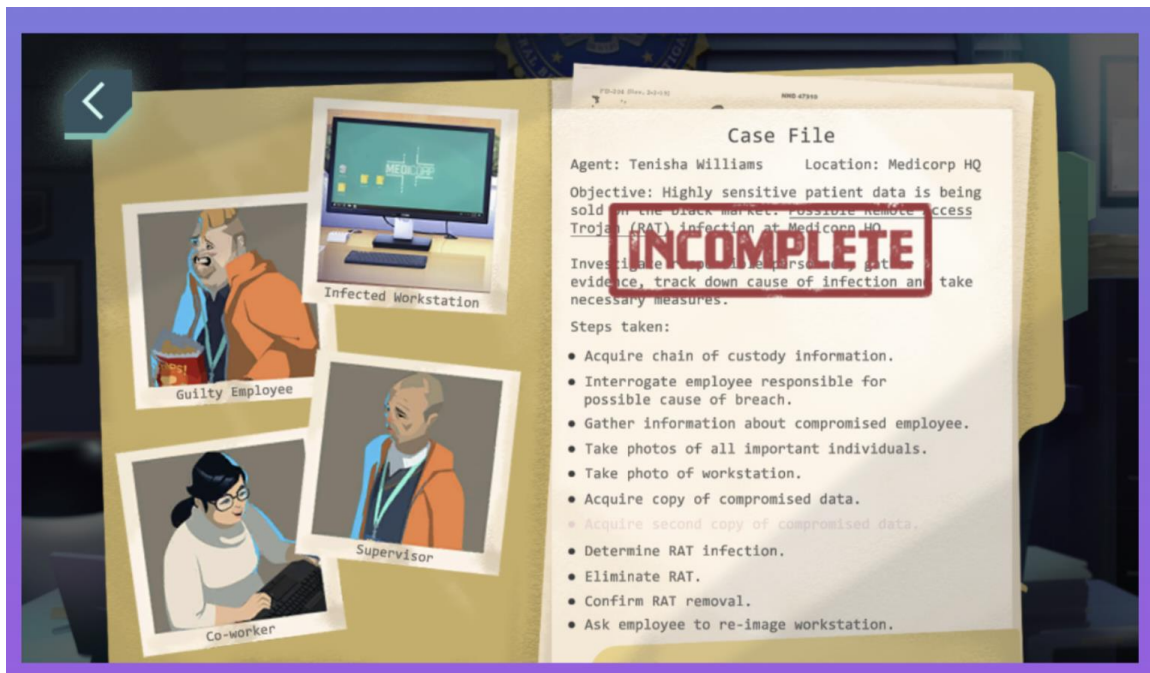
User	File	Format	Date Modified	Size	IP Address	Registry
John Doe	jama.exe	exe	07/20/2015	3.0 MB		HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion
John Doe	tempa.txt	exe	07/20/2015	8.0 MB	192.168.0.2	HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion
John Doe	paychecks.jar	jar	07/20/2015	2000 MB	192.168.0.2	
John Doe	history.jar	jar	07/21/2015	2000 MB	192.168.0.2	
John Doe	payments.jar	jar	07/21/2015	2000 MB	192.168.0.2	
John Doe	addresses.jar	jar	07/21/2015	2000 MB	192.168.0.2	
John Doe	doctors.jar	jar	07/21/2015	2000 MB	192.168.0.2	



You definitely had a nasty RAT infection. I can confirm it's been dealt with but to be absolutely safe, please reimage the workstation.



Na het verwijderen van de malware heb ik aangegeven dat alleen verwijderen niet voldoende is om volledig zeker te zijn van herstel. Daarom liet ik vastleggen dat er alsnog opnieuw een image werd gemaakt van het workstation, zodat het systeem volledig schoon en veilig terug in gebruik kon worden genomen. Dat is een belangrijke stap, omdat je bij een RAT-besmetting nooit volledig kunt vertrouwen op een systeem dat eenmaal gecompromitteerd is geweest. Tijdens de evaluatie van de opdracht bleek wel dat ik een aantal belangrijke forensische stappen niet volledig had uitgevoerd, zoals het maken van een tweede kopie van het bewijsmateriaal. Daardoor werd de case als “incomplete” beoordeeld, ondanks dat de dreiging technisch gezien al wel geneutraliseerd was.



De belangrijkste bevindingen van dit onderzoek waren dus:

- De datadiefstal hing samen met een RAT-infectie op het werkstation van een medewerker.
- De vermoedelijke besmettingsbron was het bestand 18AndUp.zip dat de medewerker had ontvangen via een verdachte online contactpersoon.
- In dat zip-bestand zaten onder andere Important.exe en Java.exe, die betrokken waren bij de besmetting.
- Er werd data doorgestuurd naar 192.168.0.2.
- De malware had persistence via registry-aanpassingen.
- Poort 31339 werd gebruikt om toegang tot het systeem te behouden.
- De infectie werd verwijderd, maar van het systeem moest voor de zekerheid een nieuwe image worden gemaakt.

Mijn conclusie is dat deze opdracht goed liet zien hoe een technisch incident vaak begint bij menselijk gedrag. In dit geval leidde onveilig online gedrag van een medewerker tot het openen van een kwaadaardig zip-bestand, waarna een RAT actief werd op het systeem. Vanuit daar kon gevoelige patiëntdata worden buitgemaakt en doorgestuurd. Door interviews, bestandsanalyse, netwerkonderzoek en malwaredetectie te combineren, kon de volledige keten van besmetting en misbruik zichtbaar worden gemaakt. Tegelijkertijd liet deze opdracht ook zien dat een goed forensisch onderzoek niet alleen draait om het stoppen van de aanval, maar ook om het volledig, zorgvuldig en reproduceerbaar vastleggen van bewijs.

Wat ik heb geleerd

Door deze opdracht heb ik geleerd dat digitaal forensisch onderzoek niet alleen bestaat uit malware vinden en verwijderen, maar vooral uit het combineren van technische analyse en contextinformatie van betrokken personen. Ik heb beter begrepen hoe een RAT zich kan nestelen via een ogenschijnlijk onschuldig bestand, hoe persistence via de registry werkt en hoe netwerkpoorten kunnen worden misbruikt voor ongewenste toegang. Ook heb ik geleerd dat het forensisch proces pas echt goed is uitgevoerd wanneer alle bewijsstappen volledig en zorgvuldig zijn doorlopen, zoals het maken van meerdere kopieën van bewijsmateriaal en het correct documenteren van alle handelingen.